

Major Compliance Frameworks by Category

- **Cybersecurity:** NIST Cybersecurity Framework (CSF 2.0), NIST SP 800-53, ISO/IEC 27001 (and related ISO 27000-series standards), SOC 2 (AICPA Trust Services Criteria), CIS Critical Security Controls, COBIT (ISACA), EU NIS Directive/NIS2, CMMC (US DoD contractors), FISMA/FedRAMP (US federal systems), and other standards (e.g. IEC 62443 for industrial control, ISO/IEC 22301 for business continuity).
- **Healthcare/Healthtech:** HIPAA (Health Insurance Portability and Accountability Act, US), HITECH (US), EU GDPR (including special provisions for health data), ISO/IEC 27799 (health informatics security), and emerging laws (e.g. draft DISHA in India, digital health data guidelines). In some regions (India/Congo) healthcare data may also be covered by general data-protection or IT laws.
- **Fintech:** PCI DSS (Payment Card Industry Data Security Standard, global for card data), GLBA (Gramm-Leach-Bliley Act, US financial privacy), PSD2 (EU Payment Services Directive 2), MiFID II/MiFIR (EU financial markets), AML/CFT regulations (e.g. Bank Secrecy Act, 6AMLD/FATF standards), and new financial-sector rules like EU DORA (Digital Operational Resilience Act) and India's RBI payments and data-localization guidelines.
- **Software Development:** Secure coding standards (e.g. OWASP Top 10, NIST Secure Software Development Framework (SSDF)), ISO/IEC 27034 (application security), MISRA C/C++ (automotive), IEC 61508 and ISO 26262 (safety-critical software), IEC 62304 (medical device software), and emerging legal regimes like the EU Cyber Resilience Act and Product Liability Directive. Industry best practices (SBOM requirements, supply-chain security) are also becoming de facto standards.

Cybersecurity Frameworks

NIST Cybersecurity Framework (CSF 2.0, US, voluntary): A risk-based set of guidelines (Identify, Protect, Detect, Respond, Recover, and Govern) originally for critical infrastructure. CSF 2.0 (released 2024) expands to all sectors and explicitly adds a "Govern" function to align security with enterprise risk management ¹. It applies to any organization seeking structured risk management and is widely used globally. Key requirements are adaptable but generally involve implementing controls (encryption, access control, network segmentation, incident response, continuous monitoring) in line with the framework's functions. It is implemented via policies, technical controls, and risk assessments. Responsibility typically falls to the CISO/Security Architect and GRC teams, with tasks like risk assessments, gap analysis, and policy documentation ¹ ².

NIST SP 800-53 (US federal): A catalog of security controls mandated by FISMA for US federal agencies and their contractors. It covers administrative, technical, and physical safeguards similar to HIPAA's triad (confidentiality, integrity, availability) ³. Controls include strong authentication, encryption of data at rest/in transit, audit logging, continuous monitoring, and incident response. Implementation is typically technical (firewalls, IAM, encryption) plus procedures. Compliance roles include IT auditors, Security Engineers, and Risk Managers who perform system inventory, classify data (FIPS/FedRAMP), and conduct annual risk assessments ⁴ ⁵.

ISO/IEC 27001 (International): An international standard for an Information Security Management System (ISMS). It applies to any organization that certifies to ISO 27001. The goal is to “protect the confidentiality, integrity, and availability” of information through a formal management system. Key requirements include an ISMS scope statement, top-management support, risk assessment, a Statement of Applicability mapping controls (from ISO 27002) to risks, and continual improvement. Technically, organizations implement controls such as encryption, access controls, physical security, and incident management. Compliance tasks include annual internal and external audits (by ISO auditors), risk assessments, policy and procedure documentation, and control implementations (e.g. firewalls, anti-malware). Security Architects and Compliance/GRC Officers typically lead 27001 programs, assisted by IT and audit teams ⁶ ⁷ .

SOC 2 (AICPA Trust Services Criteria, US/global): An auditing framework (not law) for service organizations, focusing on security, availability, processing integrity, confidentiality, and privacy. Applicable to any vendor handling customer data (especially SaaS/cloud providers). It requires implementing and documenting controls for the selected criteria (often “Security” and “Availability”). Technically, this means robust access controls, encryption, network monitoring, change management, logging, and third-party risk management. SOC 2 compliance involves a formal audit by a CPA firm that issues a report. Roles include a Compliance Manager or SOC 2 Project Lead, IT ops (for implementing controls), and an external QSA auditor. Tasks are conducting a gap analysis, remediating deficiencies, preparing control matrices, and undergoing annual audits ⁸ .

CIS Critical Security Controls: A prioritized set of best practices (20+ control families) to block or mitigate known attacks. Not a regulatory standard, but widely adopted globally as a practical framework. Organizations use them to implement layered defenses (inventory of assets, secure configurations, continuous vulnerability management, etc.). Implementation is technical (e.g. applying patches, hardening systems, enabling MFA) and organizational (policy for least privilege, incident drills). Security Engineers/Architects often map CIS controls to other compliance regimes (e.g. NIST, ISO).

COBIT (ISACA): A governance framework for enterprise IT management, covering risk, compliance, and performance. COBIT is used globally to align IT with business goals. It prescribes domains (e.g. DSS, APO) with processes like “Manage Security Services”. It is more about governance than technical specs, but helps define roles (CIO, IT Auditor, Risk Officer) and processes (risk assessment, compliance audits).

NIS Directive/NIS2 (EU): EU directives to strengthen cybersecurity for Operators of Essential Services and Digital Service Providers. NIS2 (2024) expands scope (more sectors, stricter rules). Each EU country has National CSIRT and authorities enforcing incident reporting and security measures. Key requirements include baseline security policies, incident reporting (often within 72 hours), and third-party risk management. Implementation is via technical measures (segmentation, monitoring, redundancy) and governance (CSO appointments, cybersecurity plans). Roles: National CSIRT/Regulator, company’s DPO/CSO.

CMMC 2.0 (US DoD Contractors): A certification program that (from 2025) requires defense suppliers to comply with NIST SP 800-171 and limited 800-172 controls for protecting Federal Contract Information (FCI) and Controlled Unclassified Information (CUI). It has three maturity levels (self-assess 800-171, third-party, and government-led for higher risk). Contractors’ CISOs/Security Teams must implement measures (network protections, encryption, multi-factor auth, vulnerability assessments) and pass C3PAO audits ⁹ .

FISMA/FedRAMP (US Government): FISMA requires federal agencies to inventory IT systems and apply NIST controls (via FIPS 200 and NIST 800-series) ⁴ . FedRAMP is a standardized program for cloud

providers to get authorized (implementing NIST controls plus CSP specific rules). This involves Security Engineers, ISSOs, and auditors conducting authorization packages and continuous monitoring.

Emerging Trends (2025): Major trends include embedding cybersecurity in enterprise risk management (per NIST CSF 2.0) ¹, emphasizing governance and supply-chain security. Zero Trust architectures, Software Bill of Materials (SBOM) requirements, and cloud-native security are being integrated into frameworks. Regulatory moves like the EU Cyber Resilience Act (next section) and expanded product liability (see Software below) are shifting attention to product design and update lifecycle. India is strengthening its regime (see below), and global convergence (e.g. aligning NIST with ISO standards ¹⁰) is ongoing.

Healthcare and Healthtech Frameworks

HIPAA (US, 1996 & Security/Breach Rules 2003): Governs Protected Health Information (PHI) in the US. It applies to *covered entities* (health plans, providers transmitting health data, clearinghouses) and their *business associates*. HIPAA has Privacy, Security, and Breach Notification Rules. Key requirements include: performing a risk analysis of ePHI; implementing administrative, physical and technical safeguards (e.g. access controls, encryption, audit logs, workforce training) ³; enforcing minimum necessary use/disclosure; and breach notification within 60-72 hours. Implementation is both policy-driven (Privacy Officer assigns HIPAA-compliance roles, policies, training) and technical (encrypting PHI, controlling access, using secure messaging). Privacy Officers or HIPAA Security Officers, CIOs, and compliance auditors oversee adherence. Routine tasks include risk assessments, writing/updating policies, employee training, maintaining HIPAA documentation, conducting mock breach response drills, and reviewing BA contracts.

HITECH Act (US, 2009): Extends HIPAA's Security and Privacy Rules to business associates and increases enforcement. It requires breach notifications to patients and HHS, and imposes direct liability (and fines) on BAs for violations. Technically, HITECH incentivized adoption of Electronic Health Records (EHR) and meaningful use of health IT. Organizations must therefore secure EHR systems with strong encryption and access controls. Roles under HITECH include similar ones as HIPAA, plus IT staff for EHR security.

GDPR (EU, 2016): Although a general data privacy law, GDPR treats health data as a "special category" requiring extra safeguards. It applies to any organization (even non-EU) processing EU residents' data. Key rules: lawfulness of processing (often explicit consent for health), data minimization, encryption/anonymization, breach reporting within 72 hours, and individuals' rights (access, erasure). GDPR requires appointing a Data Protection Officer (DPO) in many cases, maintaining records of processing, and doing Data Protection Impact Assessments (DPIAs) for high-risk processing like health. Technical implementation involves strong data protection (e.g. pseudonymization, logging), strict access controls, and monitoring. Enforcement officers (DPOs, legal counsel, GRC analysts) ensure policies, conduct audits, and liaise with data protection authorities. Real-world consequences of non-compliance have been severe (e.g. multi-million-euro fines ¹¹ for major breaches of personal data).

ISO/IEC 27799 (2016): International standard specifically for health information security. It adapts ISO 27002 controls to the healthcare context, addressing EHR, telemedicine, and patient data. It recommends encryption of health records, audit trails, and secure data exchange protocols. Organizations use it to complement HIPAA/GDPR compliance. Implementers include Health IT security engineers and privacy officers, and tasks are risk assessment of clinical systems, implementing specific controls (like device management for connected medical devices), and ensuring business associate agreements cover ISO-level security requirements.

India – Digital Health: India currently has no HIPAA-equivalent law, but initiatives like the National Digital Health Mission (NDHM) are creating a Health ID system and interoperability standards. While India’s new DPDP Act (2023) covers all personal data, health data security in practice is often treated under general IT Act provisions. Healthcare firms in India typically follow ISO 27001 and often voluntarily adopt frameworks like HIPAA/SOC2 to reassure global partners.

Congo: The Democratic Republic of Congo has no specific health data law. Data protection in healthcare defaults to its general Digital Code (2023) which broadly covers personal data ¹². Enforcement and technical compliance are minimal. Many healthcare providers in Congo lack robust ePHI protections; international NGOs operating there often impose their own standards (e.g. complying with HIPAA-like safeguards) to protect patient data.

Fintech Frameworks

Framework	Region/ Jurisdiction	Applies To	Key Requirements
PCI DSS	Global (card brands)	Any organization storing/ processing/ transmitting payment card data	12 high-level requirements (network firewall, no default passwords, encryption of CHD at rest/in transit, access controls, monitoring, testing). Regular vulnerability scans and compliance reporting are mandated.
GLBA (Privacy Rule)	United States	Financial institutions and their service providers	Disclosures of information-sharing practices to consumers; opt-out rights; safeguarding consumer financial data (FTC’s Safeguards Rule requires an information security program with administrative, technical, and physical controls) ¹³ ¹⁴ .
PSD2	European Union	Banks, payment service providers (PSPs)	<i>Strong Customer Authentication</i> (two-factor auth for most online payments and account access) ¹⁵ ; open banking APIs for third-party PISPs/ AISPs with customer consent; real-time fraud monitoring. Roles include banks’ security architects and compliance officers implementing SCA and secure API gateways.
MiFID II / MiFIR	European Union	Investment firms, trading venues	Transparency and reporting (transaction reporting, record-keeping); best-execution obligations; limits on dark pools. Though primarily market regulations, they have IT compliance aspects (system resiliency, audit trails).

Framework	Region/ Jurisdiction	Applies To	Key Requirements
Basel III (Banking)	Global (Basel Committee)	Banks/financial institutions	Capital adequacy ratios, liquidity coverage ratio, risk management processes. Not data-security per se, but requires rigorous risk governance (e.g. stress tests). Compliance tasks include financial modeling and risk data aggregation.
DORA	European Union	Financial entities (banks, insurers, investment firms)	Digital operational resilience: mandatory ICT risk management, incident reporting (major ICT incidents to regulator), regular cyber testing (e.g. penetration testing). Adopted in 2022 with compliance deadlines by 2025. Technical controls: network security, backup, and runbooks. GRC teams and ICT risk officers are responsible.
RBI Payment Data Rules	India	Payment system operators (PSPs, banks)	All payment-related data (including PII and financial details) must be stored on servers in India ¹⁶ . This includes end-to-end transaction records and customer identifiers (Aadhaar, PAN, mobile, etc.). Implementation: data localization (cloud or data center in-country). The RBI audit/compliance staff enforces this.
RBI PA/PG Guidelines	India	Payment Aggregators/ Gateways	Licensing of PAs/PGs; minimum capital, data confidentiality, dispute resolution procedures, and daily settlement within 24 hours. Security measures (ISO 27001 certification often mandated) and regular reporting are required. Roles: compliance officers in fintech firms ensure RBI circular adherence, conduct internal audits.

PCI DSS (Payment Card Industry Data Security Standard): Mandated by card brands (Visa, Mastercard, etc.) on all merchants/processors handling credit cards. It mandates encrypting cardholder data (CHD) in storage and transit, using secure networks (firewalls, no default passwords), vulnerability management (regular scans/patching), strict access control (unique IDs, MFA), logging/monitoring, and a formal security policy. Non-compliance can mean losing the ability to process cards and heavy penalties. For example, Target's 2013 breach (40M cards) exposed that lack of network segmentation (a PCI DSS control) let attackers reach CHD. Target ultimately settled for ~\$18.5M and then invested in segmentation, SIEM, and other PCI-aligned defenses ¹⁷.

GLBA (Gramm-Leach-Bliley Act, US): Focuses on consumer financial privacy. Its Privacy Rule requires financial institutions (banks, insurers, credit unions, mortgage lenders, etc.) to disclose their information-sharing and give opt-out rights. The Safeguards Rule (FTC-enforced) mandates that covered entities and certain financial service providers maintain a written information security program with administrative,

technical, and physical safeguards. In 2023, the FTC amended the Safeguards Rule to require more concrete guidance and breach notification ¹⁸ ¹⁴ . Key technical measures include encryption of sensitive data, strong access controls, intrusion detection, and incident response planning. Chief Privacy Officers and CISOs at banks/insurers oversee compliance, often doing regular risk assessments, vendor security audits, and ensuring GLBA requirements are built into IT and business processes.

PSD2 (EU Payment Services Directive 2): An EU-wide banking reform (2018) that introduced *open banking*. It obliges banks to open APIs to licensed third-party *Account Information Service Providers* and *Payment Initiation Service Providers*, subject to customer consent. Crucially, it enforces Strong Customer Authentication (SCA) for online payments and account access (two-factor authentication based on at least two of: knowledge, possession, inherence) ¹⁵ . PSD2's technical implementation involves OAuth 2.0/SCA tools, tokenized APIs, and fraud monitoring systems. European banks and fintechs have had to upgrade their infrastructure and user interfaces. Roles: Bank tech teams implement API gateways and SCA systems; Compliance and IT Security staff manage PSD2 project rollouts; RegTech providers help monitor compliance. Non-compliance results in bans or fines by financial regulators.

MiFID II (EU Markets in Financial Instruments Directive): A comprehensive EU financial-market regulation with significant compliance demands. For IT, MiFID II requires extensive transaction logging and record-keeping (up to 5 years), real-time trade transparency reporting, and ensuring systems can handle complex order types and surveillance. Exchanges and broker-dealers must implement automated surveillance, backup systems, and audit trails. Financial firms assign Compliance Officers and IT Governance teams to maintain MiFID controls and reports.

Basel Accords (Basel II/III, global): These banking supervision standards (by the Basel Committee) are not IT security frameworks per se, but they require banks to have strong risk management and capital controls. Technology compliance includes robust risk-data aggregation, real-time monitoring of liquidity and market risk, and secure internal systems (for reporting). Implementation involves enterprise risk architects and bank regulators; tasks include implementing trading systems with built-in risk checks and producing regulatory reports.

RBI Guidelines (India): The Reserve Bank of India has issued several fintech-related directives. In 2018, RBI mandated **"Storage of Payment System Data"** – all payment data (transactions, customer PII, payment credentials) must reside in India ¹⁶ . Payment Aggregators/ Gateways (per RBI/DPSS/2019-20/174) must obtain licenses, segregate customer funds, settle transactions promptly, and protect data (often via ISO 27001 certification). RBI's latest **Digital Lending Guidelines** (2022) require fair practice codes and data privacy for fintech lenders. Compliance roles include banks' chief risk officers, fintech CTOs, and RBI auditors.

AML/CFT and Other Regulations: Financial institutions must also comply with Anti-Money Laundering laws (e.g. US Bank Secrecy Act, EU 6AMLD) and KYC/CDD requirements. While mostly process-driven, they involve technical controls like transaction monitoring systems and secure ID verification. The FTC Safeguards Rule (GLBA) and state privacy laws (like CCPA) also affect financial data handling.

Evolving Trends (2025): Fintech compliance is shifting toward operational resilience and cybersecurity. The EU DORA (effective 2025) and similar frameworks require robust ICT risk management (e.g. cloud risk, third-party vendor management). Data protection laws (e.g. new India DPDP) now affect fintech data practices. Banks and fintechs are investing in APIs and encryption to meet open-banking and data-privacy rules. In

India, RBI is increasingly active (mandating cloud audits, data localization) and fintech startups must also watch for global standards (like GDPR) if they serve international customers. In Congo, the financial sector largely follows Basel standards via its central bank, but oversight of fintech is minimal; most Congo banks use a mix of global best practices and regional supervisory guidance (e.g. Bank of Central African States norms).

Software Development and Liability Frameworks

Secure Coding Standards: Industry best practices like the OWASP Top10 and OWASP Secure Coding Guidelines provide developers with common security pitfalls (injection flaws, broken auth, etc.) and how to avoid them. These are not laws, but major companies adopt them as internal standards. NIST's Secure Software Development Framework (SP 800-218) formalizes "security by design" processes (e.g. threat modeling, code reviews). In practice, Secure Development roles (DevSecOps Engineers, Security Architects) integrate SAST/DAST tools, enforce code-signing, and review pull requests for vulnerabilities. Development tasks include input validation, output encoding, using vetted libraries, and generating a Software Bill of Materials (SBOM) for transparency – a practice encouraged by regulators (e.g. US executive orders on SBOMs).

ISO/IEC 27034 (Application Security): Provides guidance on embedding security into each phase of the software lifecycle. Applicable to any software vendor or IT department, it maps controls (like authentication and logging) specifically to applications. It encourages using security frameworks (NIST, OWASP) in development. Implementation involves architects and QA engineers performing security tests (fuzzing, pentesting) and formal verification steps.

Industry Standards: In automotive and industrial sectors, standards like MISRA C/C++ (safe coding for embedded systems) and IEC 61508/ISO 26262 (functional safety for automotive) require suppliers to follow strict development processes (documented design, rigorous testing). Similarly, medical device software is subject to IEC 62304 and FDA guidance, demanding validation and risk analysis of software modules. These standards assign roles like Software Safety Engineer and test engineers to ensure compliance, with tasks including code traceability, hazard analysis, and regular audits.

EU Cyber Resilience Act (2024 Regulation): The newly adopted Cyber Resilience Act (CRA) mandates that software (and hardware) products sold in the EU be designed and maintained with cybersecurity. It applies to any "product with digital elements" (broadly, most software). CRA requires manufacturers and importers to implement "essential cybersecurity requirements" such as secure development practices, vulnerability management (patching/updating), encryption by default, and a documented security lifecycle ¹⁹. For example, software must have no known exploitable vulnerabilities, use secure defaults, allow secure deletion of user data, and receive timely updates ¹⁹. Critical products may need third-party certification. Manufacturers (and their security teams) must conduct risk assessments and provide CE markings. This regulation shifts compliance responsibility onto product vendors (security architects, product managers). Non-technical roles (compliance officers, legal) must also track EU guidance. The CRA goes into force in late 2024, with main obligations by Dec 2027.

EU Product Liability Directive (2024 update): In Dec 2024 the EU expanded its product liability rules to explicitly cover software, SaaS, and AI ²⁰. This means vendors in the EU can be held liable if software defects (including cybersecurity vulnerabilities) cause consumer harm. While not a technical framework, it creates a de facto requirement for secure development: companies may need to demonstrate they followed

industry standards (e.g. SSDLC, CRA requirements) to avoid presumption of defectiveness. Security and legal teams in software firms must now consider potential liability; tasks include documenting security testing, issuing patches, and possibly providing guarantees of update support.

IoT and Device Security Laws: The US (California's SB-327) and other jurisdictions require basic security features on IoT devices (unique passwords, vulnerability patching). Though narrow, these signal growing legal emphasis on development practices. Developers and QA teams must ensure IoT firmware has updatable software components.

Supply Chain Security (SBOMs, SLSA): Government directives (e.g. US EO 14028) now require supply-chain transparency. Organizations building software for government contracts must produce a Software Bill of Materials and follow build-chain integrity practices. Tasks include inventorying open-source components (to avoid vulnerabilities) and establishing reproducible build pipelines.

Roles and Tasks: Overall, software compliance tasks involve integrating security into CI/CD pipelines (automated security checks), conducting threat modeling, and responding to vulnerability disclosures. Roles include Developers (implement secure code), Security Architects (design secure architectures), DevOps Engineers (deploy CI/CD security gates), and Compliance Officers (track adherence to standards/regulations). In regulated industries, there may also be Product Security Officers who handle CRA/product liability dossiers, and Quality/Assurance Engineers who verify compliance with ISO/IEC standards.

Regional Notes: India and Congo

- **India:** Apart from following global frameworks (NIST, ISO, PCI, GDPR), India has introduced its own data-protection law: the Digital Personal Data Protection Act (2023). It applies to any entity processing Indian residents' personal data (even abroad) ²¹. It mandates consent or lawful basis, data minimization, breach notification, and imposes fines up to ₹250 crore (~USD 30M) for violations ²². In fintech, RBI rules (data localization, payments) are unique. Healthcare and other sectors currently rely on this new law and the general **IT Act** (with sections on "sensitive personal data"). India's policies on secure coding and product security are evolving (e.g. government advisories on IoT and DHS guidelines), but no standalone software safety law exists yet. Adoption of ISO 27001 and SOC 2 is common in Indian companies servicing global clients.
- **Congo (DRC):** Cyber and data-protection regulation is nascent. The 2023 **Digital Code** includes personal data protection provisions, but its implementing decrees and data-protection authority (APD) are not yet fully established ¹². The DRC has signed the African Union's Malabo Convention (2014) on cybersecurity, but local enforcement is weak. In practice, multinational firms operate under their home-country rules (e.g. GDPR) in Congo. Compliance frameworks like ISO 27001 or HIPAA-equivalents are voluntary or implemented by international NGOs. Congolese law does not specifically mandate standards like PCI or SOC 2, though global card schemes and partners typically expect PCI compliance. Overall, organizations in Congo default to global best practices (encryption, firewalls, access control) with limited national oversight.

Real-World Examples

- **HIPAA Enforcement:** The U.S. Department of Health & Human Services (HHS) has imposed large fines for HIPAA violations. For example, a major insurer was fined **\$6.85 million** in 2020 after a breach exposed 10.5 million patients' records ²³ ²⁴. HHS noted "systemic noncompliance" – no adequate risk analysis, no encryption, and poor access controls ²³. The insurer was also sued for tens of millions more. This incident underscores HIPAA's mandate for risk assessment and strong technical safeguards, and shows that compliance officers and IT staff must proactively protect ePHI (encrypting databases, performing regular audits, etc.).
- **PCI DSS Breach – Target:** In 2013, Target's retail systems were compromised through a third-party vendor credential, allowing attackers to install malware on POS devices and steal 40 million payment card records ²⁵ ¹⁷. Target ultimately paid ~\$18.5M in multistate settlement fees ¹⁷. Post-breach, Target invested heavily in network segmentation, managed SIEM and continuous monitoring, and stricter third-party risk management ¹⁷. This incident illustrated multiple PCI DSS lessons: the need to segment networks (so that a breach in one system cannot reach all card data) and to monitor/log in real-time. Its fallout prompted retailers to accelerate chip-and-PIN (EMV) rollout.
- **SOC 2 and Cloud Security:** Many cloud service companies undergo SOC 2 audits to demonstrate security. For example, Dropbox passed SOC 2 audits in 2012 to reassure enterprise customers that it met AICPA security standards. Conversely, a non-technology example: a financial app was removed from an industry marketplace in 2023 for lacking SOC 2 certification, showing how important this framework is for vendor trust.
- **GDPR Fines:** Although not healthcare-specific, GDPR enforcement shows the stakes for data protection. British Airways (2020) and Marriott (2020) faced fines (ICO proposed £183M and £99M respectively) for failing to protect customer data, demonstrating GDPR's 4%-of-revenue penalty cap ²⁶. European companies thus invest in data encryption, access logging, and DPO-led compliance to avoid such sanctions.
- **EU CRA Influence:** Although too new for real breach examples, the CRA is influencing product security already. Several European software vendors are analyzing their development lifecycles to meet CRA's "secure by design" requirements. For instance, a German industrial controls firm publicly stated it will apply CRA controls (vulnerability scanning, documentation of security features) to its software to achieve CE marking.

These cases illustrate that compliance failures often stem from missing basic controls (risk assessment, encryption, segmentation, logging). In each framework above, technical implementation (firewalls, encryption, IAM, monitoring) must be matched by governance (policies, training, documentation) and regular auditing. Roles like GRC Analyst or Security Architect are crucial for mapping these frameworks to business processes, performing gap analyses, and overseeing remediation.

Sources: Authoritative government and industry sources were used throughout (see citations) to describe the purpose, scope, and requirements of each framework ¹ ³ ²⁷ ²⁰, as well as implementation methods and roles. Where applicable, real-world enforcement actions and examples (Target breach ¹⁷, HIPAA fines ²³ ²⁴) are cited to demonstrate the importance of compliance. Each section cites the relevant standards, laws, or guides that define the frameworks.

1 4 6 7 8 10 11 27 **7 Cybersecurity Frameworks to Reduce Cyber Risk in 2025**

<https://www.bitsight.com/blog/7-cybersecurity-frameworks-to-reduce-cyber-risk>

2 17 25 **The Target Breach: A Historic Cyberattack with Lasting Consequences - Oct 01, 2024**

<https://www.frameworksec.com/post/the-target-breach-a-historic-cyberattack-with-lasting-consequences>

3 5 **Summary of the HIPAA Security Rule | HHS.gov**

<https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>

9 **Cybersecurity Maturity Model Certification Program Final Rule Published > U.S. Department of Defense > Release**

<https://www.defense.gov/News/Releases/Release/Article/3932947/cybersecurity-maturity-model-certification-program-final-rule-published/>

12 **Data protection laws in the Democratic Republic of Congo - Data Protection Laws of the World**

<https://www.dlapiperdataprotection.com/index.html?t=law&c=CD>

13 **Gramm-Leach-Bliley Act | Federal Trade Commission**

<https://www.ftc.gov/business-guidance/privacy-security/gramm-leach-bliley-act>

14 18 **FTC Safeguards Rule: What Your Business Needs to Know | Federal Trade Commission**

<https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know>

15 **Open Banking, PSD2, & Strong Customer Authentication | HYPR**

<https://blog.hypr.com/open-banking-psd2-and-achieving-strong-customer-authentication>

16 **Reserve Bank of India**

<https://www.rbi.org.in/commonman/english/Scripts/FAQs.aspx?Id=2995>

19 **The EU's Cyber Resilience Act: New Cybersecurity Requirements for Connected Products and Software**

<https://www.pillsburylaw.com/en/news-and-insights/eu-cyber-resilience-act-requirements-products-software.html>

20 **EU's Product Liability Directive & Its Cybersecurity Impact**

<https://www.darkreading.com/cybersecurity-operations/eus-new-product-liability-directive-cybersecurity-impact>

21 22 **Decoding the Digital Personal Data Protection Act, 2023 | EY - India**

https://www.ey.com/en_in/insights/cybersecurity/decoding-the-digital-personal-data-protection-act-2023

23 24 **HIPAA Violations: Examples, Fines + 5 Cases to Learn From | Secureframe**

<https://secureframe.com/hub/hipaa/violations>

26 **GDPR fines: where will BA and Marriott's £300m go? | Regulators | The Guardian**

<https://www.theguardian.com/business/2019/jul/10/gdpr-fines-ba-british-airways-marriott-data-watchdog>